Surface d’attaque exposée — Menuiserie Lacombe SARL (fictive) — TLP:AMBER — 2026-10-06

Exemple de livrable sur une autre PME fictive, avec en marge (› …) ce que la grille regarde. Ne pas recopier : la structure est la même, les constats sont ceux de votre cible.

1. Synthèse

Menuiserie Lacombe (45 salariés, `menuiserie-lacombe.example`) expose quatre hôtes dont un serveur de GED `ged.menuiserie-lacombe.example` en HTTP avec une version de Nextcloud obsolète (constat 1, priorité haute) et un accès RDP direct sur le serveur de devis (constat 2, haute). Deux adresses de salariés figurent dans une fuite de 2025 avec hachages (constat 3, moyenne). Risque global : élevé, principalement par le serveur de GED, exploitable sans identifiant. Aucune action active n’a été menée hors bac à sable. › 5 lignes, trois constats nommés, un niveau de risque global, la phrase sur ce qui n’a pas été fait.

2. Périmètre identifié

Nom	IP	Services	Technologies	Source	Confiance
www.menuiserie-lacombe.example	203.0.113.40	443	WordPress 6.4 (générateur), nginx	crt.sh, dnsx, Shodan	A1
ged.menuiserie-lacombe.example	203.0.113.41	80	Nextcloud 25.0.3 (page de connexion)	crt.sh (cert. 2024-11), Shodan	B2
devis.menuiserie-lacombe.example	203.0.113.42	443, 3389	Windows Server 2019 (bannière RDP)	Shodan	B2
mail.menuiserie-lacombe.example	203.0.113.43	25, 443, 993	Postfix, Dovecot, webmail Roundcube	Shodan, dig MX	A1
ancien-site.menuiserie-lacombe.example	—	—	NXDOMAIN (cert. expiré 2023)	crt.sh, dnsx	A1

› Un tableau, une source et une cotation par ligne ; le nom qui ne résout plus est un constat, pas une ligne vide.

3. Constats par ordre de priorité

C1 (haute). Serveur de GED exposé en HTTP avec Nextcloud obsolète. Vu : `ged.` répond en HTTP (pas de redirection TLS), page de connexion Nextcloud 25.0.3 (version lue dans la page, Shodan le 2026-10-01). Risque : versions 25.x hors support depuis 2023 ; plusieurs CVE publiques permettent la lecture de fichiers partagés sans compte ; la GED contient par nature les devis et plans des clients. Source : Shodan `203.0.113.41`, crt.sh (certificat non renouvelé depuis 2024-11). Recommandation : couper l’exposition Internet (VPN), mettre à jour vers une version supportée, vérifier les journaux d’accès depuis 2024-11. **C2 (haute). RDP exposé sur le serveur de devis.** Vu : port 3389 ouvert, bannière Windows Server 2019, nom de machine `DEVIS-SRV`. Risque : vecteur numéro un des affiliés ransomware sur les PME (accès par force brute ou identifiant fuité, voir C3). Source : Shodan, 2026-10-01. Recommandation : fermer 3389 depuis Internet, accès par VPN avec MFA, verrouillage de compte. **C3 (moyenne). Deux adresses de salariés dans une fuite.** Vu : `j.l***@` et `s.m***@` dans `fuite-2025-agregat.txt` avec hachages (fuite d’origine inconnue : F3 pour la fuite, A1 pour la présence des adresses). Risque : combiné à C2, un test d’identifiants réussi donne un accès RDP. Recommandation : réinitialisation, MFA, sensibilisation ; nous n’avons pas testé les identifiants. **C4 (moyenne). Technologies révélées par une offre d’emploi.** Vu : « administrateur maîtrisant Windows Server, Nextcloud et pfSense », offre du 2026-09-02. Risque : un attaquant sait quels exploits préparer. Recommandation : rédiger les offres sans versions ni produits. › Chaque constat : vu / risque / source / recommandation actionnable. L’ordre est celui du risque, pas celui de la découverte.

4. Personnes et identifiants exposés

Convention `prenom.nom@` (page équipe, 3 adresses). Deux adresses dans la fuite (voir C3), dont celle du gérant. Recommandation : voir C3 ; limiter les adresses nominatives sur le site (adresses de fonction). › Anonymisé, et pas de fiche sur les personnes : on parle d'adresses, pas de vies privées.

5. Ce que nous n'avons pas fait et pourquoi

Aucun scan, aucune requête vers les hôtes (hors bac à sable : interdit par la charte et par les articles 323-1 et suivants du code pénal) ; aucune tentative d'identifiant ; pas de consultation de LinkedIn connecté ; Shodan daté du 2026-10-01 (pas de vérification en direct) ; nuclei non exécuté (cible réelle). Les versions lues dans des bannières peuvent être fausses (B2). › Les limites sont écrites, avec la raison : c'est ce qui rend le rapport crédible.

6. Journal de bord (extrait)

```
2026-10-06 14:01 | périmètre | crt.sh | https://crt.sh/?q=%25.menuiserie-lacombe.example | 5
noms, ancien-site cert. expiré 2023 | A1
2026-10-06 14:09 | résolution | dnsx | sortie locale | 4 A, ancien-site NXDOMAIN | A1
2026-10-06 14:16 | exposition | Shodan | https://www.shodan.io/host/203.0.113.41 | 80/tcp
Nextcloud 25.0.3, HTTP sans TLS | B2
2026-10-06 14:24 | exposition | Shodan | https://www.shodan.io/host/203.0.113.42 | 3389/tcp
Windows Server 2019 | B2
2026-10-06 14:33 | personnes | site web | https://www.menuiserie-lacombe.example/equipe | 3
adresses prenom.nom@ | A1
2026-10-06 14:38 | fuite | grep | data/fuite-2025-agregat.txt | 2 adresses du domaine | F3 /
A1
2026-10-06 14:45 | documents | moteur | site:menuiserie-lacombe.example filetype:pdf | 1 PDF,
métadonnées auteur « s.martin » | A2
```

› Horodatage, action, outil, source, résultat, cotation. Rien n'est affirmé dans la fiche qui ne soit dans le journal.

7. Carte de la surface d'attaque

(image `carte-maltego.png`) Légende : le domaine au centre ; quatre hôtes dont trois dans le même bloc `203.0.113.0/24` (même hébergeur : une compromission de l'hébergeur touche tout) ; `ged.` et `devis.` reliés aux adresses fuitées par le serveur RDP. › Une image et trois lignes de légende qui disent ce que le tableau ne dit pas.

Marquage TLP:AMBER : la fiche contient des détails exploitables sur une organisation nommée ; diffusion limitée au membre et au CERT.